TryHackMe WriteUps: Nmap

Platform: TryHackMe
Room link: Nmap - TryHackMe

1. Introduction

Nmap (Network Mapper) is an open-source network scanning tool used to discover hosts, identify open ports, detect running services, and gather information about network devices.
It is widely used by penetration testers and security professionals during the reconnaissance and enumeration phases of a security assessment.

In this room, we explore different Nmap scanning techniques and learn how to identify network services, understand firewall behaviour, and automate scanning using the Nmap Scripting Engine (NSE).

2. Objectives

The main objectives of this room are:

- Understand how Nmap works.
- Learn commonly used Nmap switches.
- Understand different TCP and UDP scanning techniques.
- Perform network discovery using ICMP.
- Understand NULL, FIN, and Xmas scans.
- Learn how to use NSE scripts.
- Understand firewall evasion techniques.
- Analyse network traffic using Wireshark.
- Perform practical network scanning.

3. Tools and Requirements

Tool	Description
Nmap	Network scanning and enumeration
Kali Linux	Penetration testing environment
TryHackMe AttackBox	Browser-based testing environment
Wireshark	Network packet analysis
Linux Terminal	Executing scanning commands

4. Task-wise Walkthrough

Task 1 - Deploy

First, deploy the target machine provided by TryHackMe.
Launch the AttackBox or connect to the TryHackMe VPN using Kali Linux.
After the target machine starts, note its IP address.

Throughout this room, the target IP will be represented as:

TARGET_IP

Replace this placeholder with the IP address assigned by TryHackMe.
The machine is provided for network scanning exercises. There is no requirement to gain shell access or exploit the target.

Task 2 - Introduction to Nmap

Before performing a penetration test, it is important to understand the target environment.
This process is known as reconnaissance and enumeration.

Nmap helps identify:

- Active hosts.
- Open and closed ports.
- Running network services.
- Service versions.
- Operating system information.
- Potential security weaknesses.

For example, a server might have HTTP, HTTPS, SSH, and FTP services running.
Identifying these services helps security professionals understand the target's exposed attack surface.

Task 3 - Nmap Switches

Nmap provides several command-line switches that control how scans are performed.

To display the Nmap help menu:

```
nmap -h
```

To access the manual:

```
man nmap
```

Some commonly used switches:

Switch	Description
-sS	TCP SYN scan
-sT	TCP Connect scan
-sU	UDP scan
-sN	NULL scan
-sF	FIN scan
-sX	Xmas scan
-sV	Service version detection
-O	Operating system detection
-A	Aggressive scan
-p	Specify ports
-p-	Scan all TCP ports
-v	Increase verbosity

-vv	Increase verbosity further
-Pn	Skip host discovery
-sn	Host discovery without port scanning
-oN	Save normal output
-oA	Save output in multiple formats
--script	Execute NSE scripts

Example:

sudo nmap -sS -sV -O -vv TARGET_IP

This command performs a SYN scan, identifies service versions, attempts operating system detection, and provides detailed output.

Task 4 - Scan Types Overview

Nmap supports multiple scanning techniques.

The main scanning techniques covered in this section are:

i. TCP Connect Scan
ii. TCP SYN Scan
iii. UDP Scan
iv. NULL Scan
v. FIN Scan
vi. Xmas Scan

Each scanning technique uses different packet structures and communication methods. Understanding these differences helps determine how network devices and firewalls respond to scanning activity.

Task 5 - TCP Connect Scan

TCP Connect scanning establishes a complete TCP connection with the target port. It uses the TCP three-way handshake:

i. SYN - Initiates a connection.
ii. SYN-ACK - Acknowledges the connection request.
iii. ACK - Completes the handshake.

Command:

nmap -sT TARGET_IP

TCP Connect scans are useful when SYN scanning is unavailable or when a full TCP connection is required.

The scan can generate connection logs on the target system.

Task 6 - TCP SYN Scan

A TCP SYN scan is also known as a half-open scan.

Unlike a TCP Connect scan, it does not complete the entire TCP handshake.

The general process:

i. Nmap sends a SYN packet.
ii. The target responds based on the port state.
iii. Nmap sends an RST packet to terminate the connection attempt when appropriate.

Command:

sudo nmap -sS TARGET_IP

This scan is commonly used during network reconnaissance because it is efficient and does not establish a complete application connection.

Task 7 - UDP Scan

UDP stands for User Datagram Protocol.

Unlike TCP, UDP is connectionless and does not establish a three-way handshake.

It is commonly used by DNS, DHCP, and other network services.

Command:

sudo nmap -sU TARGET_IP

UDP scanning can take longer than TCP scanning because many UDP services do not respond to unexpected packets.

Nmap uses different responses to determine the state of UDP ports.

Common port states include:

- Open
- Closed
- Open|Filtered

Task 8 - NULL, FIN and Xmas Scans

These scanning techniques use different TCP flag combinations.

NULL Scan

Sends TCP packets without setting any flags.

sudo nmap -sN TARGET_IP

FIN Scan

Sends TCP packets with the FIN flag enabled.

sudo nmap -sF TARGET_IP

Xmas Scan

Sends TCP packets with FIN, PSH, and URG flags enabled.

sudo nmap -sX TARGET_IP

These scanning methods can help analyse firewall behaviour and identify how different operating systems respond to unusual TCP packets.

Their results are not always reliable, especially when scanning systems with modern firewalls.

Task 9 - ICMP Network Scanning

ICMP stands for Internet Control Message Protocol.

It is commonly used for network diagnostics and host discovery.

Nmap supports ping sweeps, allowing security professionals to identify active hosts within a network.

Example:

nmap -sn 192.168.1.0/24

The -sn option performs host discovery without conducting a port scan.

It is useful when mapping a network before beginning detailed enumeration.

Task 10 - NSE Scripts Overview

NSE stands for Nmap Scripting Engine.

It extends Nmap's functionality through scripts written in Lua.

NSE scripts can automate several security assessment activities, including:

- Service enumeration.
- Vulnerability detection.
- Network discovery.
- Authentication testing.
- Security configuration checks.

Some important NSE categories include:

Category	Description
auth	Authentication-related checks
brute	Brute-force testing
discovery	Information gathering
exploit	Exploitation-related scripts
intrusive	Potentially disruptive scripts
safe	Scripts designed to avoid disruption
vuln	Vulnerability detection

Task 11 - Working with NSE Scripts

NSE scripts can be executed using the --script option.

General syntax:

```
nmap --script SCRIPT_NAME TARGET_IP
```

Example:

```
nmap --script ftp-anon TARGET_IP
```

To execute multiple scripts:

```
nmap --script smb-enum-users,smb-enum-shares TARGET_IP
```

To execute vulnerability detection scripts:

```
nmap --script vuln TARGET_IP
```

To view information about a particular script:

```
nmap --script-help ftp-anon
```

NSE scripts are useful for automating enumeration, but they should only be executed against systems you are authorized to assess.

Task 12 - Searching for NSE Scripts

Nmap stores its NSE scripts in the following directory on many Linux distributions:

```
/usr/share/nmap/scripts/
```

To list available scripts:

```
ls /usr/share/nmap/scripts/
```

To search for SMB-related scripts:

```
ls /usr/share/nmap/scripts/*smb*
```

To search the script database:

```
grep -i smb /usr/share/nmap/scripts/script.db
```

To execute an SMB discovery script:

```
nmap --script smb-os-discovery TARGET_IP
```

This helps identify information about SMB services and the remote operating system.

Task 13 - Firewall Evasion

Firewalls monitor and filter network traffic based on configured security policies.

During network scanning, a firewall may block ICMP requests or filter certain TCP packets.

Nmap provides several options for analysing filtered network environments.
Skip host discovery

```
nmap -Pn TARGET_IP
```

Fragment packets

```
sudo nmap -f TARGET_IP
```

Specify packet fragmentation size

```
sudo nmap --mtu 16 TARGET_IP
```

Add scanning delays

```
nmap --scan-delay 1s TARGET_IP
```

Append additional data to packets

```
nmap --data-length 50 TARGET_IP
```

These options demonstrate how scanning behaviour can be modified when assessing firewall configurations. Their effectiveness depends on the network environment.

Task 14 - Practical Exercises

This task combines the scanning techniques covered throughout the room.

Use the TryHackMe target machine and perform the following exercises.

Exercise 1 - ICMP Discovery

Check whether the target responds to ICMP echo requests.

```
ping -c 4 TARGET_IP
```

Exercise 2 - Xmas Scan

Perform an Xmas scan against the first 999 ports.

```
sudo nmap -sX -p 1-999 TARGET_IP
```

Observe the port states and reasons reported by Nmap.

Exercise 3 - TCP SYN Scan

Perform a SYN scan against the first 5000 ports.

```
sudo nmap -sS -p 1-5000 TARGET_IP
```

Record the discovered open ports.

Exercise 4 - TCP Connect Scan

Perform a TCP Connect scan against port 80.

```
nmap -sT -p 80 TARGET_IP
```

Open Wireshark and analyse the TCP packets generated during the scan.
Pay attention to the SYN, SYN-ACK, ACK, and connection termination packets.

Exercise 5 - FTP Enumeration

Execute the FTP anonymous authentication check.
nmap -p 21 --script ftp-anon TARGET_IP
Examine the script output and understand how Nmap checks anonymous FTP access.

5. Key Takeaways

After completing this room, the following concepts should be familiar:

- Nmap is used for network discovery and enumeration.
- TCP Connect and SYN scans use different connection mechanisms.
- UDP scanning works differently from TCP scanning.
- NULL, FIN, and Xmas scans use specific TCP flags.
- ICMP helps identify active hosts.
- NSE automates network enumeration and security checks.
- Firewall configurations can affect scan results.
- Wireshark helps analyse network packets and understand scanning behaviour.

6. Conclusion

The Further Nmap room provides practical knowledge of network scanning and enumeration. It introduces different scanning techniques, Nmap command-line options, scripting capabilities, and firewall-related scanning behaviour.

These skills are important for understanding how network reconnaissance works and form a foundation for more advanced penetration testing activities.